RCAAS platform | Audit fix status

Updated 29 October 2026. This report supersedes the original open-findings report for the current working tree. The before-fix report and evidence are preserved as report-before-fixes.pdf / report-before-fixes.md and findings-before-fixes.json.

30 original findings: 25 fixed, 2 mitigated, 2 prepared, 1 open. Fixed means the code change is implemented with the verification described below; it does not certify a production service. Mitigated means a supported operating constraint prevents the trigger. Prepared means code/configuration is ready but external setup or restore validation remains.

The confirmed bugs have fixes or an enforced mitigation. The platform has not been deployed, and the remaining operator work below must be completed before public launch. Source changes are uncommitted; no customer runtime data was migrated or modified.

Key behavior changes: personal account login in production; restart old in-progress uploads; one API process; stale scene/site saves return 409; one room/hall booking channel per venue resource kind; engine host allowlist; backup format 2 with component archives.

Verification and practical limits

Existing baseline: 176 passing tests and one skipped. Current validation: 195 passing tests and one skipped (27 client tests; 168 server tests passing of 169). Nineteen regression/backup tests were added, including a real API production-mode startup and second-writer rejection, reset races, upload authorization and quota, booking corruption, history/ownership, edit conflicts, strict dates, ranges, engine bounds, attachment retry and local backup restore.

TypeScript noEmit passed. ESLint: zero errors and the six existing warnings (five image optimization warnings and one effect-dependency warning). Production webpack build passed into .next-new. Server dependency patch reported zero known vulnerabilities. Logs are under vps-audit/evidence/.

Local-only verification: mocks/disposable stores, loopback HTTP, and a temporary backup/restore. Real PostgreSQL execution remains skipped; PostgreSQL bootstrap/pg_dump changes need a disposable database drill. No nginx binary/TLS/firewall verification or real cloud-provider/mail/hotel service validation was done.

The application is still backed by JSON for projects/scenes/sites/bookings. It deliberately enforces a single production API process; do not enable PM2 cluster or rolling API reload. Database migration and load testing remain prerequisites for claiming large-scale capacity.

No browser/GPU/mobile sign-off was performed for lazy scene selection and booking clock changes. Build/types and server tests do not establish rendering quality or real network performance. Business/policy placeholders remain open for owner content.

Before deployment

Follow deploy/README.md. Set the actual domain and TLS paths, provision an unprivileged account, persistent data/assets, strong secrets, production frontend URLs and HTTPS CLIENT_ORIGIN. Transfer ignored runtime models and records explicitly.

Use personal accounts. Restart pre-upgrade in-progress uploads, reconcile legacy room/hall bookings before changing channels, and configure exact ENGINE_ALLOWED_HOSTS for vetted hotel adapters. Set quotas appropriate to the VPS disk.

Use one API instance and stop/start upgrades. After a forced kill/power loss, verify no writer exists before removing a stale .api.lock. Monitor failures and disk space. Do not use the report folder as a public web root.

Verify a mail sender domain and delivery to real guests; configure off-site retention/bucket versioning and separate secret backups. Restore PostgreSQL plus JSON, scans and attachments on a different machine before relying on the backup plan.

Replace placeholders with verified company facts and approved policy text. Test owner/member/staff/public workflows, every model, real devices and the intended production URLs. Decide whether to disable the second GitHub Pages deployment.

A01 | Fixed | The shared signup code also grants unrestricted administrator access

Original severity: High. Current source: server/src/routes/auth.js:74.

Production refuses shared-password login and previously issued accountless JWTs. The uploader now signs in with a personal email/password. Development compatibility remains.

Acceptance check: The signup code alone must never authenticate as admin; deleted or demoted accounts and old legacy cookies must fail authorization.

A02 | Fixed | Staff can write into any known or invented upload staging ID

Original severity: High. Current source: server/src/uploadStore.js:36.

Upload IDs have persistent owners. Staff, unknown IDs, expired uploads and other accounts are refused on init/chunk/finalize. Ownership is retained for unreferenced finalized assets. Existing in-progress uploads must restart.

Acceptance check: Staff writes return 403; a second editor cannot initialize, resume, finalize or delete another editor’s unused upload.

A03 | Fixed | Unpublish then publish cannot restore a scene to live

Original severity: High. Current source: server/src/store.js:205.

New publication numbers are allocated above all retained history, including after unpublishing. Immutable snapshots are preserved.

Acceptance check: Publish/unpublish/publish repeatedly; every attempt succeeds with a new increasing version, including after restoring older snapshots.

A04 | Fixed | Version restore rolls back scene ownership

Original severity: High. Current source: server/src/store.js:271.

Restoring history preserves the current owner and project, and updates the editing revision.

Acceptance check: Restore a snapshot after transfer/detach/delete-project flows and assert current ownerId and permissions remain unchanged.

A05 | Fixed | Booking read failures become empty inventory and can destroy records

Original severity: High. Current source: server/src/reservations.js:28.

Only a missing booking file is empty. Corruption, invalid record shape and disk failures fail closed; the original damaged file is preserved.

Acceptance check: Malformed JSON and simulated read failures must return a controlled service error and leave the original file intact.

A06 | Fixed | One-time reset links can be redeemed twice concurrently in file mode

Original severity: High. Current source: server/src/usersStore-file.js:168.

File-account mutations are serialized. A reset token has one concurrent winner; role/password/reset updates no longer race read-modify-write operations.

Acceptance check: Concurrent redemption has exactly one success. Concurrent password reset and role change preserve both the new password and intended role.

A07 | Fixed | Concurrent first signups both become administrators

Original severity: Medium. Current source: server/src/usersStore-pg.js:57.

File bootstrap is serialized and checks physical account files before declaring an empty store. PostgreSQL uses a transactional advisory lock for first signup. PostgreSQL implementation is source-reviewed; real database execution remains pending.

Acceptance check: Concurrent initial registration creates at most one admin; staff invitation must never unexpectedly become admin.

A08 | Fixed | Public enquiries accept nonexistent or unpublished scene references

Original severity: Medium. Current source: server/src/routes/leads.js:15.

Enquiries require a published scene or a real project hub. Unknown/draft scene requests return 404 instead of creating orphan leads. Project routing comes from the published scene.

Acceptance check: Unknown/draft scenes cannot create leads; published tours route enquiries to the project shown to visitors.

A09 | Fixed | Corrupt website state is silently treated as a new website

Original severity: High. Current source: server/src/routes/sites.js:58.

Website read failures propagate rather than returning null and overwriting publication/review/schedule state.

Acceptance check: Invalid JSON yields a controlled error and a draft save cannot replace the damaged state.

A10 | Fixed | External availability response size is checked after full buffering

Original severity: Medium. Current source: server/src/engine.js:59.

Engine bodies are streamed with a 64 KiB cap and a four-second total timeout; oversized bodies are destroyed before full buffering.

Acceptance check: A response over the cap is aborted before full consumption and peak memory stays bounded under simultaneous requests.

A11 | Fixed | Suffix byte ranges return incorrect file content

Original severity: Medium. Current source: server/src/routes/assets.js:531.

Suffix byte ranges now return the final N bytes. Empty, zero-length and unsatisfiable ranges are refused.

Acceptance check: Verify bytes=-3, bytes=-100, bytes=3-, bytes=-0, zero-length files and large integer boundaries.

A12 | Fixed | Byte ranges extending past EOF are rejected unnecessarily

Original severity: Medium. Current source: server/src/routes/assets.js:533.

A satisfiable range extending past EOF is clamped to the last byte rather than rejected.

Acceptance check: Check bytes=0-99 returns the complete 10-byte file as 206, while bytes=10-99 returns 416.

A13 | Fixed | Booking dates are validated by shape rather than calendar validity

Original severity: Medium. Current source: server/src/calendar.js:2.

Server booking entry points require a strict calendar round trip, including leap years. Invalid dates cannot reach the night generator.

Acceptance check: Reject November 31, February 30, month 00/13 and day 00; accept valid leap days and enforce date windows.

A14 | Fixed | One bad scene can break the entire studio scene list

Original severity: Medium. Current source: server/src/records.js:4.

Malformed listing records are logged and isolated from healthy scene/account/lead listings. Public gallery reads likewise isolate corrupt scene JSON. Damaged individual records still require operator recovery.

Acceptance check: One bad record is detected and alerted without taking unrelated accounts, projects or public listings offline.

A15 | Mitigated | Website and hotspot bookings do not share room/hall inventory

Original severity: High. Current source: server/src/routes/reservations.js:405.

One booking channel per room/hall resource kind is enforced. Hotspot requests/marks are refused while website booking is enabled. Publishing/scheduling a switch is blocked by active legacy hotspot bookings; live website guest requests also refuse legacy conflicts. Resource IDs have not been unified; reconcile existing bookings before switching.

Acceptance check: Booking through either channel blocks overlapping requests/confirmations/marks through the other.

A16 | Mitigated | Multiple API processes bypass in-memory booking locks

Original severity: High. Current source: server/src/processLock.js:6.

Production refuses another API writer for the same DATA_DIR. PM2 configuration uses one instance and fixed loopback ports. This enforces the supported single-process architecture; it does not implement multi-node transactions or shared distributed rate limits.

Acceptance check: Run a two-process last-table contention test after the storage fix; exactly one reservation succeeds and no records disappear.

A17 | Fixed | Concurrent project/scene/site updates can lose edits and permission changes

Original severity: High. Current source: server/src/serial.js:7.

Metadata mutations and website scheduling are serialized. Full scene and website edits carry revisions and stale edits return 409. Upload operations use a separate queue so model finalization does not hold the metadata queue. Multi-file crash consistency still depends on recovery/backups; this is not a database migration.

Acceptance check: Race publish/save, membership changes, claims and scheduled publish; all intended updates survive or receive explicit conflicts.

A18 | Fixed | Uploads have no total quota, expiry or ZIP expansion budget

Original severity: High. Current source: server/src/uploadStore.js:9.

Defaults: 8 GiB/upload, 20,000 files, 100 GiB/account for uploads with ownership records, 20 active uploads/account, 24-hour staging expiry and disk headroom checks. ZIP extraction checks expansion count/bytes/path depth while extracting. Pre-upgrade orphan staging needs reviewed manual cleanup; existing assets without metadata are outside the new quota ledger.

Acceptance check: Small-budget tests stop oversized uploads safely, remove partial extraction, and leave capacity for normal bookings.

A19 | Fixed | Concurrent chunks can overwrite each other after the offset check

Original severity: Medium. Current source: server/src/uploadStore.js:51.

Chunks/finalization are serialized with an ownership recheck inside the queue. Same-offset concurrent chunks yield one success and one conflict.

Acceptance check: Two same-offset chunks produce one accepted write and one conflict; finalize cannot race an unfinished chunk.

A20 | Fixed | Engine URL filtering does not prevent DNS-based private network access

Original severity: Medium. Current source: server/src/engine.js:42.

Production engine hosts require an explicit allowlist and HTTPS/443. DNS is validated in the socket lookup and the connection uses the validated result; private, loopback and link-local addresses are refused. Redirects are not followed. Configure vetted adapter hosts before enabling real integrations.

Acceptance check: A controlled hostname resolving to loopback/private/link-local addresses is refused without initiating the connection.

A21 | Fixed | Public room availability can trigger uncapped engine requests

Original severity: Medium. Current source: server/src/engine.js:93.

Availability reads are rate limited; external engine work has a four-request concurrency cap, in-flight deduplication, bounded input and failure caching.

Acceptance check: A local fake engine sees bounded requests under a flood of varied dates; healthy callers still receive timely responses.

A22 | Fixed | Attachment upload consumes its one-time key before saving the file

Original severity: Medium. Current source: server/src/routes/reservations.js:697.

Attachment file storage succeeds before consuming the one-time key. A simulated storage failure preserves the key and a retry succeeds. Private attachment metadata is committed in the booking queue.

Acceptance check: Inject a storage failure: the guest can retry with the original key and the inbox does not show a nonexistent attachment.

A23 | Prepared | The backup command does not back up PostgreSQL accounts or external local assets

Original severity: High. Current source: server/scripts/backup-data.js:56.

Backup format 2 includes JSON, external local assets and optional PostgreSQL app-schema dump plus a manifest. JSON and external asset restore passed locally. Real PostgreSQL restore, bucket backup/versioning, secured secret backup and off-VPS recovery still need deployment verification. Archive format changed: use deploy/README.md restore steps.

Acceptance check: Restore into an empty machine/database; confirm accounts, permissions, booking history, attachments, scene JSON and every scan all work.

A24 | Prepared | VPS deployment files are absent and production defaults are permissive

Original severity: High. Current source: deploy/README.md:1.

Added nginx/TLS starter configuration, one-instance PM2 setup, environment example and restore instructions. Production API binds loopback by default, enforces HTTPS CLIENT_ORIGIN, refuses example secrets and fails on port conflicts. Actual VPS provisioning, nginx validation, DNS/certificates/firewall and account-level settings have not been performed.

Acceptance check: Test from an external machine: only intended HTTPS ports are open, cookies are secure, API routing works, restarts retain data, and a port conflict fails visibly.

A25 | Fixed | Some Express 4 async authentication handlers do not forward rejected promises

Original severity: Medium. Current source: server/src/middleware/auth.js:79.

Async admin and session handlers catch lookup failures and forward to Express error handling. Fault-injection checks receive controlled 500 responses without terminating the API.

Acceptance check: Force account lookup to reject and assert a sanitized 5xx response, no hung request, and continued API health.

A26 | Fixed | Server lockfile includes a qs version flagged by npm audit

Original severity: Medium. Current source: server/package-lock.json:881.

Updated the compatible server qs dependency. npm audit fix reported zero vulnerabilities after the update; the lockfile is changed. No forced major upgrades were applied.

Acceptance check: Server audit has no remaining advisory and query parsing/API regressions still pass. Source: https://github.com/advisories/GHSA-6pq8-jhm2-2vcw

A27 | Fixed | Private booking attachments are missing from git ignore rules

Original severity: Medium. Current source: .gitignore:46.

Private attachments, ownership records and the default API lock are now ignored by git. Production runtime data is configured outside the code checkout.

Acceptance check: git check-ignore confirms a sample default-path attachment is ignored; no guest files are tracked.

A28 | Fixed | Tour defaults assume Nepal even when the venue uses another timezone

Original severity: Medium. Current source: src/features/booking/HotspotBookCard.tsx:72.

Hotspot booking reads the configured venue timezone from a public clock endpoint and uses it for date defaults/minimums and outgoing booking links. Submission waits for the clock.

Acceptance check: Check venues in Kathmandu, Honolulu and Auckland around midnight with visitors in different timezones.

A29 | Fixed | Tour first render waits for every published scene in the project

Original severity: Medium. Current source: src/app/tour/TourClient.tsx:77.

The public tour loads the starting document first; sibling documents load on selection. API fetches have bounded timeouts and superseded scene loads are ignored. Production build/type checks pass; first-frame and motion performance still need real GPU/mobile measurements.

Acceptance check: With one sibling scene delayed or failed, the requested healthy scene still opens within the first-frame target on a real mobile device.

A30 | Open | Public marketing content still contains editorial placeholders

Original severity: Low. Current source: src/features/marketing/pages/GameWorldsPage.tsx:50.

Business facts and policy placeholders require verified owner content. No company details, licensing promises or legal policy wording were invented. Review rendered public pages before launch.

Acceptance check: Crawl rendered public pages for TBI/TBC, broken contact actions and draft content before launch.

Artifacts and rerunning checks

Current report.pdf/report.md and findings.json/fix-status.json describe the working-tree fixes. Original detailed triggers/reproductions are retained in report-before-fixes.pdf/.md, findings-before-fixes.json and reproductions.log.

Run npm test, npx tsc --noEmit, npm run lint and npm run build for regression validation. The historical reproduce.mjs intentionally asserted that bugs existed; it is preserved for audit history and must not be used as the post-fix passing test suite. Current regression tests are in server/test/vps-regressions.test.js and server/test/backup.test.js.

This review cannot establish that every bug is found or that the platform is ready for any traffic level. Keep the report private: it documents security-sensitive behavior and deployment constraints.